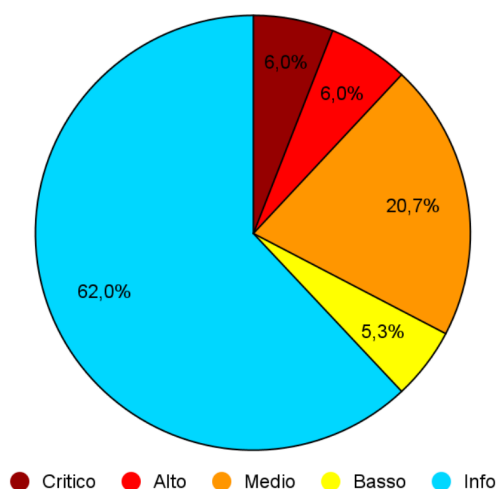


Analisi vulnerabilità e azioni di rimedio

In questo progetto di fine modulo viene assegnata una delle fasi del Penetration Test: l'**analisi delle vulnerabilità**. Per eseguire questa scansione ci siamo attrezzati di un tool chiamato **Nessus**, uno scanner di vulnerabilità il quale è stato scaricato ed installato nella nostra VM Kali Linux.

In questo progetto abbiamo usato un client (Kali) con ip 192.168.50.100 e un target (Metasploitable) con ip 192.168.50.101 e che operano in una rete interna.

Una volta avviato Nessus da Kali iniziamo a cercare le possibili vulnerabilità di Metasploitable evidenziando il livello di criticità di ogni debolezza riscontrata.



In questo grafico è possibile osservare quante debolezze, o vulnerabilità, sono state individuate durante la scansione. Come possiamo ben vedere il target della nostra scansione risulta molto vulnerabile, questo in parte è dovuto al fatto che il target utilizzato è reso volontariamente vulnerabile in modo da capire come poter proteggere o attaccare la macchina.

Una volta completata la scansione ed individuate tutte le vulnerabilità e la loro criticità andiamo ad effettuare le “soluzioni” delle potenziali in modo da riuscire a rendere la macchina target più “sicura”.

VCN Server ‘password’ Password

Questa è una debolezza con un livello di criticità 10.0 (il più elevato). Il server VCN in esecuzione sull’host remoto è protetto da una password debole. Questo potrebbe permettere ad un possibile aggressore di entrare con facilità e prendere il controllo del sistema.

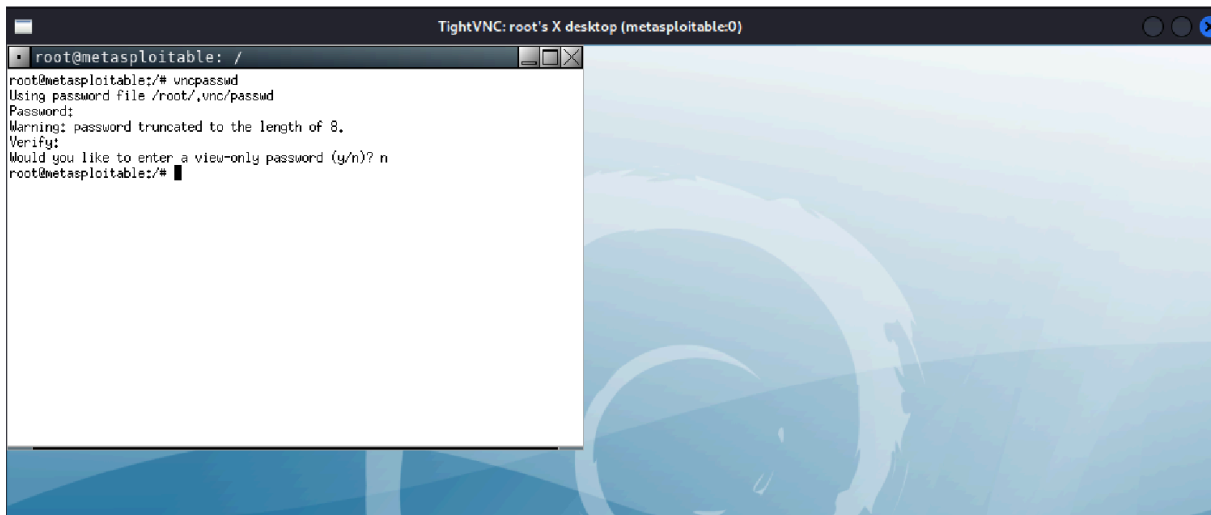
La soluzione per risolvere questa vulnerabilità è quella di cambiare la password tramite terminale di metasploitable, in alternativa possiamo anche cambiarla tramite Kali connettendosi alla VCN.

metodo metasploitable

```
root@metasploitable:~# vncpasswd
Using password file /root/.vnc/passwd
Password:
Warning: password truncated to the length of 8.
Verify:
Would you like to enter a view-only password (y/n)? n
root@metasploitable:~#
```

metodo Kali

```
(kali@kali)~$ vncviewer 192.168.50.101:5900
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "root's X desktop (metasploitable:0)"
VNC server default format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```



Bind Shell Backdoor Detection

Anche questa è una debolezza critica, come quella precedente, ma il livello di criticità è leggermente minore: 9.8.

Questa debolezza indica che una shell è in ascolto su una porta remota senza che sia richiesta alcuna autenticazione. A causa di questa porta c'è il rischio che un aggressore possa connettersi tramite essa inviando, così, comandi direttamente.

Soluzione a questa problematica è impedirne l'accesso tramite una modifica tramite firewall su entrambe le macchine. Bisogna prestare attenzione in quanto questa è una contromisura temporanea perché il codice della backdoor è ancora nel sistema e potrebbe aggirare anche l'intervento effettuato.

passaggi metasploitable

```
msfadmin@metasploitable:~$ sudo iptables -A INPUT -p tcp --dport 1524 -j drop

msfadmin@metasploitable:~$ sudo iptables -L
Chain INPUT (policy ACCEPT) 61 PCS Systemtechnik/Oracle VirtualBox virtual NIC
target      prot opt source                destination
DROP dpt: postgresql  tcp -- anywhere (1 up) scanned anywhere 5 seconds  tcp dpt:postgresql
DROP dpt: smtp      tcp -- anywhere            anywhere      tcp dpt:smtp
DROP dpt: ingreslock tcp -- anywhere            anywhere      tcp dpt:ingreslock
```

passaggi Kali

```
(kali㉿kali)-[~]
└─$ nmap -p 1524 192.168.50.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-18 14:21 EDT
Nmap scan report for 192.168.50.101
Host is up (0.00018s latency).
ACCEPT tcp 1524 192.168.50.101
PORT      STATE      SERVICE
1524/tcp  filtered  ingreslock
MAC Address: 08:00:27:CC:EB:61 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
target      prot opt source                destination
Nmap done: 1 IP address (1 host up) scanned in 0.35 seconds
```

Bisogna però prestare attenzione qui, in quanto questa è una contromisura temporanea, perché il codice della backdoor è ancora nel sistema e potrebbe aggirare anche l'intervento effettuato. Se la

macchina fosse compromessa bisognerebbe ripulire l'intero sistema reinstallandolo.

NFS Shares World Readable

Qui abbiamo una debolezza con un livello di criticità decisamente inferiore alle due precedenti, ovvero 7.5.

Il server NFS remoto sta esportando una o più condivisioni senza limitare l'accesso: in base al nome host, all'IP o all'intervallo IP. A causa di questa mancanza di restrizioni di accesso, un aggressore potrebbe intercettare o manipolare le comunicazioni tra i server NFS e i client, soprattutto se la rete non è protetta o è vulnerabile a questi attacchi.

Per risolvere questo problema basta impostare le opportune restrizioni su tutte le condivisioni NFS.

```
GNU nano 2.0.7      File: /etc/exports
/etc/exports: the access control list for filesystems which may be exported
to NFS clients.  See exports(5).

Example for NFSv2 and NFSv3:
/srv/homes          hostname1(rw, sync) hostname2(ro, sync)

Example for NFSv4:
/srv/nfs4            gss/krb5i(rw, sync, fsid=0, crossmnt)
/srv/nfs4/homes      gss/krb5i(rw, sync)

*(rw, sync, no_root_squash, no_subtree_check)
```

[Read 12 lines]

Get Help WriteOut Read File Prev Page Cut Text Cur Pos
Exit Justify Where Is Next Page UnCut Text To Spell

```
GNU nano 2.0.7      File: /etc/exports
# /etc/exports: the access control list for filesystems which may be exported
# to NFS clients.  See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes          hostname1(rw, sync) hostname2(ro, sync)
#
# Example for NFSv4:
# /srv/nfs4            gss/krb5i(rw, sync, fsid=0, crossmnt)
# /srv/nfs4/homes      gss/krb5i(rw, sync)
#
/data 192.168.50.100(ro, sync, root_squash)
```

Debian OpenSSH/OpenSSL Package Random Number Generator Weakness

Anche questo è una debolezza con un livello di criticità 10.0. Qui la chiave host SSH remota è stata generata su un sistema Debian o Ubuntu che contiene un bug nel generatore di numeri casuali della sua libreria OpenSSL. Il problema è dovuto alla rimozione da parte di un pacchettizzatore Debian su quasi tutte le fonti di entropia nella versione remota di OpenSSL. Le porte che sono interessate sono la 22, la 25 e la 5432.

A causa di questa debolezza un aggressore può facilmente ottenere la parte privata della chiave remota e utilizzarla per decifrare la sessione remota.

Per risolvere questo problema bisogna considerare tutto il materiale crittografico generato sull'host remoto come indovinabile. In particolare, tutto il materiale delle chiavi SSH, SSL e OpenVPN dovrebbe essere rigenerato. Dato che è irrisolvibile in questi casi per mitigare il più possibile è anche qui necessario usare delle regole firewall, lasciando solamente il libero accesso alla nostra macchina Kali in modo tale da poterci collegare tramite la porta 22 compromettendo, così, la rivelazione di criticità da parte di Nessus.

```

msfadmin@metasploitable:~$ sudo iptables -A INPUT -p tcp --dport 22 -s 192.168.50.100 -j ACCEPT
msfadmin@metasploitable:~$ sudo iptables -A INPUT -p tcp --dport 22 -j DROP
msfadmin@metasploitable:~$ sudo iptables -A INPUT -p tcp --dport 25 -j DROP
msfadmin@metasploitable:~$ sudo iptables -A INPUT -p tcp --dport 5432 -j DROP

msfadmin@metasploitable:~$ sudo iptables -L
[sudo] password for msfadmin:
Chain INPUT (policy ACCEPT)
target     prot opt source                destination            tcp dpt:postgresql
DROP       tcp  --  anywhere               anywhere               tcp dpt:smtp
DROP       tcp  --  anywhere               anywhere               tcp dpt:ingreslock
ACCEPT     tcp  --  192.168.50.100         anywhere               tcp dpt:ssh
DROP       tcp  --  anywhere               anywhere               tcp dpt:ssh

Chain FORWARD (policy ACCEPT)
target     prot opt source                destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source                destination

```

Canonical Ubuntu Linux SEoL

Questa è una debolezza con un livello di criticità 10.0.

In questa versione del sistema, essa ha raggiunto la “End of Life”, ovvero che non riceve alcun aggiornamento di sicurezza dal fornitore perché non più sostenuta da molto tempo.

A causa di ciò le sue vulnerabilità “non aggiornate” possono essere sfruttate da un possibile attaccante che potrebbe compromettere la sicurezza dell’host.

Come soluzione possiamo aggiornare la macchina a una versione supportata, installando l’ultima versione Ubuntu disponibile.

```

msfadmin@metasploitable:~$ lsb_release -a
No LSB modules are available.
Distributor ID: Ubuntu
Description:    Ubuntu 8.04
Release:       8.04
Codename:      hardy

```

(versione obsoleta)

Apache Tomcat SEoL

Questa è un'altra debolezza con un livello di criticità 10.0

In questa versione del sistema, essa ha raggiunto la “End of Life”, ovvero che non riceve alcun aggiornamento di sicurezza dal fornitore perché non più sostenuta da molto tempo.

A causa di ciò le sue vulnerabilità “non aggiornate” possono essere sfruttate da un possibile attaccante che potrebbe compromettere la sicurezza dell’host.

Come soluzione possiamo aggiornare la macchina a una versione supportata, installando l'ultima versione disponibile.

[illegible]

(versione obsoleta)

Se per dei motivi bisogna lasciare aperto il servizio, potremmo avere una criticità in più da risolvere. Se, invece, l'utilizzo di questo servizio non è necessario, potremmo eliminare 2 criticità usando semplicemente il comando "kill" sui vari processi attivi di tomcat.

Ecco le procedure :

- Visualizzazione dei processi attivi

[illegible]

- Processi non più attivi dopo l'utilizzo del comando


```
msfadmin@metasploitable:~$ sudo kill 4564 4565 4567
[sudo] password for msfadmin:
msfadmin@metasploitable:~$ ps aux | grep tomcat
msfadmin 5049  0.0  0.0  3004  756 pts/1    R+   10:07   0:00 grep tomcat
```

Porte attive:

8009/tcp open ajp13

Apache Jserv (Protocol v1.3)

8180/tcp open http

Apache Tomcat/Coyote JSP engine 1.1

```
(kali@kali)-[~]
$ nmap -sV 192.168.50.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-18 08:55 EDT
Nmap scan report for 192.168.50.101 Apache Tomcat SSL (v=5.5.x)
Host is up (0.000066s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath gmicregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:CC:EB:G1 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 52.41 seconds
```

Porte chiuse:

```

kali@kali:~$ nmap -sV 192.168.50.101 -oN nmap.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-18 10:20 EDT
Nmap scan report for 192.168.50.101
Host is up (0.000062s latency).
Not shown: 979 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-remote  GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  x11          (access denied)
6667/tcp  open  irc          UnrealIRCd
MAC Address: 08:00:27:CC:EB:61 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 36.44 seconds

```

phpMyAdmin prior to 4.8.6 SQLi vulnerability

Questa è una vulnerabilità con un livello di criticità 9.8

In base al numero di versione auto-dichiarato, l'applicazione phpMyAdmin ospitata sul server web remoto è precedente alla 4.8.6. E' quindi affetta da una vulnerabilità di tipo SQL injection presente nella funzionalità di progettazione di phpMyAdmin.

Per causa di ciò un aggressore remoto non autenticato può sfruttarla per iniettare o manipolare query SQL nel database back-end, con conseguente divulgazione o manipolazione di dati arbitrari.

Come soluzione si può aggiornare phpMyAdmin alla versione 4.8.6 o superiore oppure, in alternativa, applicare le patch indicate negli avvisi di fornitore.

- soluzione vulnerabilità all'interno del codice sorgente fornitore

```

768 768         S(this).dialog('close');
769 769     };
770 770
771 771     var Sform = S('<form action="db_designer.php" method="post" name="save_page" id="save_page" class="ajax"></form>');
772 772     .append('<input type="hidden" name="server" value="' + server + '" />');
773 773     .append('<input type="hidden" name="db" value="' + db + '" />');
774 774     .append(S('<input type="hidden" name="db" />').val(db));
775 775     .append('<input type="hidden" name="operation" value="savePage" />');
776 776     .append('<input type="hidden" name="save_page" value="new" />');
777 777     .append('<label for="selected_value">' + PHA_messages.strPageName +
778 778         '</label><input type="text" name="selected_value" />');
779 779     Sform.on('submit', function (e) {
780 780         e.preventDefault();
781 781         submitSaveDialogAndClose(callback);

```

Apache PHP-CGI Remote Code Execution

Questa è una vulnerabilità con un livello di criticità 9.8

L'installazione di PHP sul server web remoto contiene una falla che potrebbe consentire a un aggressore remoto di passare argomenti della riga di comando come parte di una stringa di query al programma PHP-CGI.

Questo potrebbe essere sfruttato per eseguire un codice arbitrario, rivelare il codice sorgente PHP, causare un crash di sistema ecc.

Come soluzione possiamo aggiornare a PHP 5.3.13/5.4.3 o versione successiva, oppure disabilitare il supporto PHP-CGI se non è esattamente necessario.

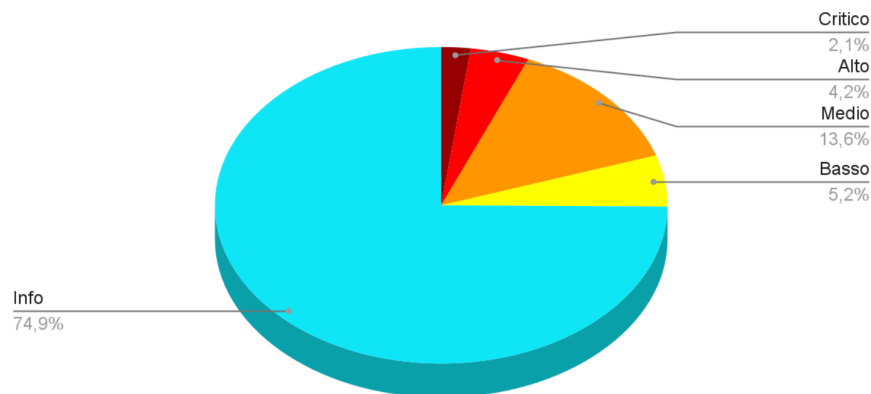
Ecco il comando che abbiamo utilizzato:

```

root@metasploitable:/etc/init.d# sudo a2dismod cgi
Module cgi already disabled

```

Dopo aver eseguito tutte le modifiche per mitigare le vulnerabilità, possiamo procedere con la scansione tramite Nessus in modo da verificare che esse siano effettivamente risolte o quantomeno mitigate.



Come possiamo vedere alcune vulnerabilità non sono state risolte del tutto ma sono state mitigate abbastanza per non facilitare troppo i possibili attaccanti ad accedere alla macchina. Alcune vulnerabilità trovate da nessus sono:

- **Canonical Ubuntu Linux SEoL** = non risolvibile se non usando un'altra versione
- **Debian OpenSSH/OpenSSL Package Random Number Generator Weakness** = porta 22 lasciata aperta di proposito ma limitata l'accesso solo all'host kali
- **phpMyAdmin prior 4.8.6 SQLi vulnerability** = possibile soluzione tramite modifica al codice sorgente dichiarata dal fornitore

Critico	Alto	Medio	Basso	Info
4	8	26	10	143

Perciò, durante la prima scansione con Nessus, abbiamo rilevato un ampio numero di problematiche.

Nella fase di scansione, effettuata con Nessus, ha rivelato un ampio spettro di problematiche, tra cui servizi obsoleti, configurazioni errate e vulnerabilità note e sfruttabili. In seguito sono state applicate una serie di contromisure mirate (es disattivazione servizi inutilizzati).

Nella seconda scansione abbiamo notato una riduzione generale del rischio, pur evidenziando la permanenza di alcune vulnerabilità non completamente risolvibili nel contesto simulato. Tuttavia queste misure di mitigazione ha comunque migliorato il livello di sicurezza generale.

Per concludere è molto importante eseguire un processo ciclico di valutazione e miglioramento continuo ottimizzando la sicurezza della macchina per ridurre la superficie d'attacco e limitare i rischi.